ROALLA



EXECUTIVE SAAS SOC 2 READINESS GUIDE

SaaS SOC 2 Readiness and Business Value Guide 2026

A decision framework for building auditable controls, customer trust and scalable operations

Prepared for Canadian SaaS boards, founders, chief executives, technology, security, product, operations, finance, legal, privacy, sales and customer success leaders

Prepared by ROALLA Transformation and Technology Advisory

Status date: 6 October 2026

Purpose

This guide helps a SaaS company prepare for a SOC 2 examination while improving the operating system behind customer trust. It connects report strategy, system scope, governance, cloud architecture, secure delivery, access, resilience, vendors, evidence and commercial readiness so assurance work strengthens the business rather than becoming a documentation exercise.

EXECUTIVE DECISION DASHBOARD

Management View at a Glance

SOC 2 readiness is achieved when important controls are deliberately designed, consistently operated and supported by reliable evidence. SOC 2 is an independent examination and report, not a generic certification. Leadership should choose scope and timing with the CPA firm, remediate material gaps before the examination period and use the resulting discipline to improve customer assurance and operating scale.

Executive question	ROALLA view	Decision implication
Why is the company pursuing SOC 2?	**CONDITIONAL**	Connect the examination to customer requirements, market strategy, risk and operational maturity.
Which report path is appropriate?	**DECIDE**	Align Type I or Type II objectives, criteria, scope, period and timing with a qualified CPA firm.
Are controls operating beyond policy?	**PREPARE**	Verify repeatable execution, complete populations, exceptions, approvals and evidence over time.
Can scope be explained and defended?	**CONDITIONAL**	Confirm the system description, cloud responsibilities, vendors, data flows and customer commitments.
What should management authorize?	**PURSUE**	A 90-day SOC 2 readiness diagnostic and remediation mobilization.

Recommended Management Posture

Proceed through a small number of explicit decision gates. Preserve evidence as work occurs, separate discovery from implementation, and require each investment to demonstrate value, feasibility, control effectiveness and accountable ownership before scale.

EXECUTIVE DECISION MODEL

The Eight SaaS SOC 2 Readiness Gates

A credible SOC 2 program starts with the service commitments and system customers rely on, then connects risks to controls, owners, evidence and management review. Automation can improve evidence collection, but it cannot replace accountable control design or operating effectiveness.

Stage	Gate	Required conclusion	Decision evidence
01	Assurance strategy	The business purpose and report path are explicit	Customer need, intended users, Type I or Type II path, timing and CPA alignment
02	System boundary	The in-scope service is described completely	Products, infrastructure, people, processes, data, locations and subservice organizations
03	Governance and risk	Leadership owns risks and control decisions	Oversight, risk assessment, policies, exceptions, reviews and accountability
04	Identity and access	Access is authorized, limited and reviewed	Joiner-mover-leaver, MFA, privilege, service accounts and periodic review
05	Secure delivery	Software and changes are controlled	SDLC, code review, testing, approvals, deployment, vulnerabilities and rollback
06	Operations and resilience	The service is monitored and recoverable	Logging, alerting, incidents, backups, continuity, recovery testing and capacity
07	Data and third parties	Customer data and dependencies are governed	Classification, retention, encryption, privacy, vendors and shared responsibility
08	Evidence and assurance	Controls operate with reliable proof	Owners, frequency, populations, exceptions, remediation, management assertions and auditor access

Decision Rule

A failed hard gate moves the initiative to Prepare or Monitor. A strong narrative, senior sponsor or attractive market cannot replace missing authority, evidence, delivery capacity or operating control.

SECTION 01

Readiness Framework

Translate ambition into a shared executive view of value, evidence, capability and risk.



MANAGEMENT ASSESSMENT MODEL

Readiness Dimensions

No.	Decision area	Management evidence	Status
01	Assurance strategy and scope	Business objective, intended users, report type, criteria, boundary and system description	**Confirmed / Developing / Gap**
02	Governance and risk	Oversight, risk assessment, policies, ownership, exceptions and management review	**Confirmed / Developing / Gap**
03	Identity and security	Authentication, authorization, privilege, endpoints, configuration, vulnerabilities and monitoring	**Confirmed / Developing / Gap**
04	Engineering and operations	SDLC, change, deployment, availability, incidents, problems and capacity	**Confirmed / Developing / Gap**
05	Data resilience and vendors	Classification, encryption, retention, backup, recovery, privacy and third-party dependencies	**Confirmed / Developing / Gap**
06	Evidence and assurance	Control design, frequency, populations, proof, exceptions, remediation and auditor coordination	**Confirmed / Developing / Gap**

Evidence Standard

Assessments should distinguish verified evidence from management confidence. Where evidence is incomplete, record the gap, owner, completion date and decision that depends on it.

STRATEGIC READINESS DEPENDENCIES

What Readiness Depends On

Dependency	Why it matters	Evidence management should expect
Assurance strategy	The business purpose and report path are explicit	Customer need, intended users, Type I or Type II path, timing and CPA alignment
System boundary	The in-scope service is described completely	Products, infrastructure, people, processes, data, locations and subservice organizations
Governance and risk	Leadership owns risks and control decisions	Oversight, risk assessment, policies, exceptions, reviews and accountability
Identity and access	Access is authorized, limited and reviewed	Joiner-mover-leaver, MFA, privilege, service accounts and periodic review
Secure delivery	Software and changes are controlled	SDLC, code review, testing, approvals, deployment, vulnerabilities and rollback
Operations and resilience	The service is monitored and recoverable	Logging, alerting, incidents, backups, continuity, recovery testing and capacity
Data and third parties	Customer data and dependencies are governed	Classification, retention, encryption, privacy, vendors and shared responsibility
Evidence and assurance	Controls operate with reliable proof	Owners, frequency, populations, exceptions, remediation, management assertions and auditor access

ROALLA Interpretation

Dependencies should be evaluated as a connected system. A weakness in ownership, data, architecture, delivery or governance can change the economics and risk of an otherwise attractive initiative.

SECTION 02

Detailed Readiness Assessment

Convert executive intent into verifiable requirements, accountable evidence and clear remediation actions.



READINESS CHECKLIST

Strategy Scope and Governance Readiness

Completion standard Mark Ready only when the supporting evidence has been verified. Assign an evidence owner to every open item.

Gate	Readiness requirement	Ready	Gap	Evidence owner
A01	The business objective identifies customers, sales requirements, risk outcomes and intended users of the report.	☐	☐	_____
A02	Management and a qualified CPA firm have discussed the appropriate Type I or Type II path and timing.	☐	☐	_____
A03	The selected trust services categories reflect customer commitments, contractual obligations and actual service risk.	☐	☐	_____
A04	The system boundary identifies products, infrastructure, software, people, procedures, data, locations and dependencies.	☐	☐	_____
A05	The draft system description reflects how the SaaS service actually operates and avoids unsupported claims.	☐	☐	_____
A06	Executives approve security objectives, risk acceptance, policy exceptions, resources and control accountability.	☐	☐	_____
A07	A documented risk assessment connects threats, commitments and dependencies to specific control responses.	☐	☐	_____
A08	Policies have owners, approval, communication, review dates and evidence of operational implementation.	☐	☐	_____
A09	Asset, data, application, integration and vendor inventories are complete enough to support the defined scope.	☐	☐	_____
A10	Contracts, security materials and sales claims are consistent with the controls and service commitments in scope.	☐	☐	_____

READINESS CHECKLIST CONTINUED

Control Operation and Evidence Readiness

Completion standard Use Gap to create a dated remediation action and identify the management decision that cannot proceed.

Gate	Readiness requirement	Ready	Gap	Evidence owner
B01	Joiner, mover and leaver access is approved, timely, least-privileged and periodically reviewed.	☐	☐	_____
B02	MFA, privileged access, service accounts, secrets and production access use documented safeguards and monitoring.	☐	☐	_____
B03	Software changes retain requirements, review, testing, approval, deployment and rollback evidence.	☐	☐	_____
B04	Vulnerabilities and configurations are identified, prioritized, remediated and exception-managed to defined standards.	☐	☐	_____
B05	Security events are logged, monitored, investigated and retained with ownership and escalation.	☐	☐	_____
B06	Incident response is documented, exercised and connected to notification, learning and corrective action.	☐	☐	_____
B07	Backups, restoration, continuity and disaster recovery are tested against approved service objectives.	☐	☐	_____
B08	Critical vendors undergo due diligence, contracting, ongoing review and accountable exception management.	☐	☐	_____
B09	Personnel complete role-appropriate security training and acknowledge relevant policies and responsibilities.	☐	☐	_____
B10	Each control has an owner, frequency, evidence source, population, reviewer and remediation process.	☐	☐	_____

WEIGHTED EXECUTIVE ASSESSMENT

Readiness Scorecard

Dimension	Weight	Evidence standard	Score	Status
Assurance strategy and scope	20%	Business objective, intended users, report type, criteria, boundary and system description	__/20	Strong / Developing / Gap
Governance and risk	20%	Oversight, risk assessment, policies, ownership, exceptions and management review	__/20	Strong / Developing / Gap
Identity and security	15%	Authentication, authorization, privilege, endpoints, configuration, vulnerabilities and monitoring	__/15	Strong / Developing / Gap
Engineering and operations	15%	SDLC, change, deployment, availability, incidents, problems and capacity	__/15	Strong / Developing / Gap
Data resilience and vendors	15%	Classification, encryption, retention, backup, recovery, privacy and third-party dependencies	__/15	Strong / Developing / Gap
Evidence and assurance	15%	Control design, frequency, populations, proof, exceptions, remediation and auditor coordination	__/15	Strong / Developing / Gap
TOTAL	100%	Weighted executive assessment	__/100	Pursue / Prepare / Monitor

Decision Thresholds

Score	Posture	Management decision
75 to 100	**PURSUE**	Proceed to bounded execution subject to no hard-gate failure.
50 to 74	**PREPARE**	Complete a focused readiness plan before major commitment.
0 to 49	**MONITOR**	Resolve foundational gaps before investing further.

A single material hard-gate failure overrides the weighted score. ROALLA also applies judgment where administrative readiness is high but strategic value, adoption or commercial viability is weak.

SECTION 03

Execution and Advisory Roadmap

Establish scope and control ownership first, remediate operating gaps second, and begin the examination period only when evidence can be sustained.



READINESS OPERATING PLAN

Recommended 90 Day Mobilization

Timing	Focus	Key activities	Management output
Days 1 to 15	Align	Confirm business drivers, intended users, CPA engagement path, scope hypotheses and executive ownership.	Approved assurance mandate
Days 16 to 35	Assess	Map the system, risks, commitments, criteria, controls, vendors, evidence and current operating gaps.	SOC 2 readiness fact base
Days 36 to 55	Remediate	Prioritize control design, policy, technical, process, vendor and evidence improvements.	Owned remediation plan
Days 56 to 75	Validate	Test control execution, populations, samples, exceptions, system description and evidence quality.	Validated readiness position
Days 76 to 90	Authorize	Approve remaining actions, examination timing, evidence cadence, auditor access and communications.	Executive examination plan

Twelve to Twenty Four Month Path

- Quarter 1: define scope, complete the readiness assessment, assign owners and remediate priority control gaps.
- Quarter 2: operate controls consistently, complete internal testing and begin the agreed examination or observation period.
- Quarters 3 and 4: address exceptions, complete the report process and integrate customer assurance into sales and renewals.
- Year 2: maintain continuous control ownership, expand scope only where business value and operating maturity support it.

ROALLA ADVISORY MODEL

How ROALLA Can Help

ROALLA acts as the technology, governance and commercialization advisor for SOC 2 readiness. ROALLA coordinates the SaaS operating model, cloud and product architecture, control design, evidence, vendors, remediation and customer assurance while the independent CPA firm retains responsibility for the SOC 2 examination and opinion.

ROALLA workstream	Executive value
SOC 2 readiness diagnostic	Establish an independent fact base across scope, commitments, controls, evidence and operating maturity.
Scope and report strategy	Clarify business drivers, system boundary, trust services categories, intended users and CPA coordination.
Risk and control architecture	Connect SaaS risks and commitments to practical controls, owners, frequencies and evidence.
Cloud and product readiness	Assess identity, configurations, SDLC, change, monitoring, incidents, resilience and shared responsibility.
Policy and operating model	Align policies, procedures, roles, exceptions, reviews, training and management governance.
Vendor and data governance	Strengthen due diligence, contracts, monitoring, privacy, classification, retention and subservice oversight.
Evidence and remediation	Build evidence maps, validate populations, test operation and coordinate corrective action.
Customer assurance enablement	Align report use, security responses, sales claims, renewals and ongoing control assurance.

Recommended Initial Mandate

- Four-week SaaS SOC 2 readiness and business value diagnostic.
- Verified system boundary, criteria, risk, control, vendor and evidence fact base.
- Prioritized remediation roadmap with owners, dependencies and examination readiness gates.
- Executive readout and 90-day mobilization plan coordinated with the selected CPA firm.

CONTROL FRAMEWORK

Key Risks and Controls

Risk	Exposure	ROALLA control
Certification language	Marketing presents SOC 2 as a generic certification or guarantee.	Use accurate examination and report language reviewed with the CPA firm and counsel.
Tool-led readiness	Automation is mistaken for control ownership.	Design the control, owner, evidence and review before configuring collection technology.
Over-scoping	An unnecessarily broad boundary increases cost and delay.	Define the customer-relevant service, commitments, dependencies and intended report use.
Paper compliance	Policies describe controls that teams do not operate.	Test real workflows, populations, approvals, exceptions and management review.
Snapshot evidence	A point-in-time cleanup cannot support sustained operation.	Build routine evidence and remediation before the Type II observation period.
Cloud responsibility gap	Provider capabilities are assumed to cover customer controls.	Map shared responsibilities, configurations, monitoring and complementary controls.
Vendor blind spot	Subservice organizations introduce unmanaged dependencies.	Inventory, assess, contract, monitor and represent vendor responsibilities accurately.
Commercial overclaim	Sales commitments exceed audited scope or operating reality.	Govern security claims, questionnaires, report distribution and exception escalation.

Professional Advice

Qualified legal, privacy, security, tax, accounting, employment and regulatory advisors should validate matters within their professional scope. ROALLA coordinates those inputs with technology strategy, architecture, commercialization, governance and transformation decisions.

OFFICIAL EVIDENCE BASE

Selected Official Sources

These sources support the management principles summarized in this guide. Standards, laws, guidance and organizational obligations continue to evolve and must be confirmed for the specific context before acting.

AICPA SOC for Service Organizations overview. Official source — Authoritative overview of SOC reports for service organizations and third-party risk assurance.

AICPA Trust Services Criteria. Official source — Authoritative criteria for controls relevant to security, availability, processing integrity, confidentiality and privacy.

AICPA System and Organization Controls suite. Official source — Official SOC guidance, criteria and reporting resources for service organizations and practitioners.

Canadian Centre for Cyber Security baseline controls. Official source — Canadian baseline cyber controls for small and medium organizations.

NIST Cybersecurity Framework 2.0. Official source — Outcome-based framework for governing and managing cybersecurity risk.

NIST Secure Software Development Framework 1.1. Official source — Secure-development practices for software producers and acquirers.

CISA Secure by Design. Official source — Official guidance encouraging software manufacturers and SaaS providers to make customer security outcomes a core product responsibility.

Office of the Privacy Commissioner of Canada privacy for businesses. Official source — Canadian guidance for private-sector privacy management and responsible handling of customer information.

Advisory Disclaimer

This ROALLA guide is a strategic readiness and marketing document. It is not a certification, audit opinion, legal opinion, privacy opinion, security assurance, investment recommendation or guarantee of results. Management must validate current obligations, company facts and professional advice before making material decisions.